CM22014 – Cybersecurity

Coursework: Payment Card Exercise

Professor James Davenport

Set: Monday 02/02/2026 (week 1 of this module) **Due: A) Friday 06/03/2026 (week 5 of this module), 20:00** **B) Friday 27/03/2026 (week 8 of this module), 20:00** **C) Friday 01/05/2026 (week 11 of this module), 20:00**
Percentage of overall unit mark: 60% (0%/40%/20% for the three parts)
Submission Location: Moodle **Submission Components: Data, Report, Report** **Submission Format: .zip for (Part A); .pdf (Parts B,C)**
Anonymous Marking: No

For CM22014, this assessment involves investigating the cybersecurity of the payment card system: first through making a (notional) purchase, then analysing this, then via a group comparative exercise.

Formative feedback on your work will be offered throughout the duration of the coursework:

- During this exercise I will be available to answer questions and offer guidance. Please note that I will not be able to make decisions on behalf of you or your group about the course of the project. I am there to discuss your ideas and offer advice.
- Use Moodle forums to post general questions or questions specific to your project. The unit convener will respond to these as well as your peers. This way we will create a repository of knowledge that will be available to all.

You will receive **summative feedback** on your work within 3 semester weeks of the submission deadline. The feedback will discuss your performance based on the criteria for marking, including what you did well and how specific sections could have been improved.

For **Generative AI**, in terms of https://teachinghub.bath.ac.uk/guide/genai-assessment-categorisation/ this is a Type B assignment: you may use generative AI (for any part of the coursework), but you should acknowledge its use. If you make significant use of a generative AI output, you should quote that output in a footnote (not counted against word count) in the format "Based on Bing Chat in Creative Mode on 21/Jan/2025 which replied <insert raw response>". Note that all answers should

refer back to the data you collected: generic answers will get a failing mark.

Your work will be checked to ensure that you have not plagiarised. For more information about the plagiarism policy at the University see: https://library.bath.ac.uk/referencing/plagiarism

Remember that published work that you refer to in your report should be clearly referenced in your text and listed in a bibliography section given at the end of your report. For more information see, https://library.bath.ac.uk/referencing/new-to-referencing

Requests for extensions should be made to the Director of Studies. Lecturer and tutors cannot approve extensions.

Payment Card Exercise

This assignment comes in three parts, each following from the previous. The precise dates and weightings are given on the submission pages for each part. Parts A and B are individual; Part C is a group exercise, done in groups assigned on the basis of the outputs from Part A.

Part A: Individual Data Collection

1) Choose a fake payment card. Note that if you just type in 16 digits as your card number, it is unlikely to be syntactically correct: many sites do give correct card numbers for this purpose, e.g. https://www.freeformatter.com/credit-card-number-generator-validator.html or https://ccardgenerator.com/ .
2) Create a file card.txt containing *all* the personal details from the card generator: card number (PAN), CVV, expiry date, holder's name, address etc.
3) Collecting the data described below as you do, attempt to make a purchase from a site of your choice.
    a. The complete log (HAR file) of the browser from the **start of the transaction** (i.e. when you first go to the merchant site) to the point where the payment is declined. There's a FNU (Feature of Negative Utility) in Chrome (at least v84): if you are working in one tab, with logging on, and get switched to a different tab, the different tab doesn't automatically get logged (whereas an iframe in the same tab should get logged). Beware that this might mean you don't log the critical part. The fix to this is to tick the option "preserve logs". Other browsers may have similar issues.
    b. The actual web page[1] into which you entered the PAN, i.e. after the last digit but before you press enter/move to next field/whatever else moves the process on. Also, record precisely the (computer) time at which you move the process on, and the time at which all the card data is entered. This may help you correlate with entries in the HAR. You may wish to pause a few seconds before and after submitting the PAN, to isolate the relevant transactions more clearly in the HAR. **Add this time to card.txt**
    c. A screenshot of this page at the same point.
4) Bundle (a), (b), (c) *and* the card.txt file into a single zip, and submit this.
    a. If the file is too big, use Dropbox or some such service for the HAR and submit a text file with the details in the zip file.

[1] That is, the result of doing "cast, save, share" then "save page as" in Chrome, or the equivalent in other browsers.

Part B: Individual Analysis

Based on the HAR you have captured, answer the following questions. I have provided some length guidance, but these are not requirements.

1) [50% of Part B] With which *sites*, e.g. https://google.com *not* https://google.com/maps, does your browser communicate during the transaction? Are there any that worry you, or whose function you do not understand? Note that protocols other than https might be used, e.g. http or wss. The level of detail I expect depends on the number of sites.
    a. <21 sites. A list of each site and its apparent purpose. The list should be numbered.
    b. 21..50 sites. Either as above or with some grouping, e.g. "10 analytics sites, viz …", but each site should be named.
    c. >50 sites. As either method above, but you can group different sites from the same domain, e.g. "7 sites under stripe.com".

    [Probably 4-8 pages, depending on number of sites and difficulty]

2) [20% of Part B] To which site, or sites, does the *complete* PAN get communicated. State the line(s) in the HAR that evidence this. Note that if the PAN is encrypted, this may require a certain amount of deduction ("educated guesswork"), and the times recorded in A3(b) may be useful here. How is the PAN protected in transit? Was it obvious, from the transaction as you observed it as a purchaser (i.e. *not* using the logs) that your data would go there? [Probably 1-2 pages]
3) [20% of Part B] How dependent is the correct functioning of the process you saw on the correct functioning of the DNS? Answer these questions.
    a. Could a subverted DNS by itself result in leakage of the PAN (with or without the CVV)? If it couldn't, what else might you need to subvert?
    b. If you were a financially-motivated criminal and could completely subvert the connection to ONE site in your process, which would you choose and why? Outline the attack you would use after the subversion.

    c. If that domain is not subvertable, what would your second choice of *domain* for subversion be. Again, outline the attack you would use.

    [Probably ½ page to a page]

4) [10% of Part B] Looking at the HTML etc. you have saved, do you feel confident you know what it is doing with your data? In particular, what did you learn from the logs/HTML that you could not have reasonably deduced as a purchaser with no access to these? In particular, what security precautions do you observe in the traffic? You may find the "OWASP Top 10" useful – I find the 2017 edition (https://owasp.org/www-project-top-ten/2017/) more helpful at this point.
    [Probably ½ page to a page, possibly plus screenshots]

Part C: Group Exercise. Groups (of 5±1) will be announced by JHD after he has analysed the results of Part A, to ensure groups have a mix of experience at Part A. There will be a "group contribution" sheet to ensure people all contribute: details when groups are announced.

1) Your company is looking to start a new online shop, and the websites your group has been looking at in Part B are the samples provided by the various potential suppliers (refer to the suppliers by the name of the website). Your group is a group of

cybersecurity experts, writing a recommendation to the CISO on the cybersecurity of these sample sites. This is a reasonably typical activity (I've done similar activities) except that normally the team would do the equivalent of question 2 before doing the equivalent of part B. Recall that this is a collective exercise, and normally you will all get the same marks. I will not normally unpick and say "the analysis of XYZ Corp was really good, and in Part B that was done by Fred, so they should get extra marks. Hence I would suggest that, while obviously the author of XYZ Corp in part B will make the first stab at question 3 for XYZ Corp., the others should at least read it. In particular, you will lose marks if the various question 3 are inconsistent (in real life, this would lead to appeals against the evaluation).

2) [20% of Part C] See a typical scored ranking at the end. Decide on the criteria and weights for your scoring analysis (4-6 criteria would be usual). Write a brief explanation (typically one page in all) of the criteria, referring to the PCI DSS requirements (The PC standard is available on the Part C coursework page) if appropriate.

3) [40% of Part C] Give a brief (1/2 page each) cybersecurity analysis (strengths and weaknesses) of each site. Note that these are *not* simply summaries of Part B: they should be written in a common format based on the criteria above, and justify the individual entries.

4) [20% of Part C] Provide the scored ranking, with justification based on these analyses. You should give a strict ranking with no ties, but you can add comments like “2 and 3 were very close”, “major gap between 3 and 4”.

5) [20% of Part C] Are there any features (cybersecurity or not) that you saw in these sites that should be recommended for inclusion (or exclusion), e.g. “aardvark.com would have come higher if it hadn’t subcontracted PAN verification to armadillo.br over http”.

Example scoring for Part C

Note that it up to the group acting as a scoring team (in practice they would do this in advance, and many procurement frameworks would insist that the suppliers were informed in advance of the criteria and scores) what weights to allocate to each criterion. Note also that tie-breaking needs some justification.

Explanation of a sandwich rating system.

The filling is the most important of a sandwich, hence we give it twice the weighting of the other three criteria, so 40% of the whole weighting.

The bread is also important, and often neglected.

Sandwiches are in general meant to be eaten on the move, or at least without plates and cutlery, so a good sandwich has to be easy to eat. Included in this is easy disposability.

Sustainability is a relevant factor, as well. But B provided no information, and the rest only talked about the sustainability of the packaging, in identical terms.

Feature	Max	A	B	C	D	E
Filling (quantity and quality)	10	9	4	5	6	7
Bread	5	2	3	4	3	2
Ease of Eating	5	2	4	4	3	3
Sustainability	5	2	0	2	2	2
Total Score	25	15	11	15	14	14
Ranking		1st	5th	2nd	3rd	4th

A and C score equal top, but A's filling was so much better than the rest that it ranks above C.

D and E also tied, and were equally easy to eat, but D's filling matched its bread better, so has a slight edge.